

Summary

ID	Change	Effort	Blocks mobile?
P0-1	Add GET /auth/me	~8 lines	Yes — hard blocker
P0-2	Accept Authorization: Bearer header	~10 lines	Yes — hard blocker
P1-1	Fix role enum mismatch	1 line	No — causes runtime failures

1. Add GET /auth/me

DOCKED

The problem

When the mobile app restarts, it has no way to tell whether the user is still signed in. Tokens are stored in HttpOnly cookies, so JavaScript cannot read them. **/auth/refresh** only returns a success message with no user information. So on every cold start the app is blind — it cannot tell if the session is alive or who it belongs to.

There is a second problem in the same fix. **login** returns the User document. **hierarchyLevel** lives on the Employee document. There is currently no endpoint that returns it. Without it the app cannot draw the navigation — it needs to know whether someone is a MANAGER or an INTERN before it can decide which screens to show them.

Good news: req.employee is already attached by auth.middleware.js on every authenticated request. No extra database query is needed.

Change required

auth.routes.js

```
router.get('/me', authenticate, authController.me);
```

auth.controller.js

```
const me = async (req, res, next) => {
  try {
    return res.status(200).json({
      success: true,
      data: {
        user: req.user, // toJSON strips password + refreshTokenHash
        employee: req.employee, // already attached by auth.middleware.js
      },
    });
  } catch (error) {
    next(error);
  }
};
```

What this fixes

- Cold start: app can call GET /auth/me on launch to check if a session is alive
- Identity: employee record including hierarchyLevel is available after login
- Post-refresh rehydration: session can be restored after token rotation

2. Accept Authorization: Bearer header

DOCKED

The problem

passport.js currently uses **cookieExtractor** as its only token source. On mobile, the native cookie jar (OkHttp on Android, NSHTTPCookieStorage on iOS) cannot be reliably managed from JavaScript. The app cannot check token expiry, cannot clear the session cleanly on logout, and behaviour differs between Android and iOS.

Important: Adding a second extractor does not change web behaviour at all. Cookies keep working exactly as they do today. This only adds a fallback path for mobile clients.

Change 1 of 2 — passport.js

Add a second extractor alongside the existing one.

```
jwtFromRequest: ExtractJwt.fromExtractors([
  cookieExtractor,
  ExtractJwt.fromAuthHeaderAsBearerToken(), // add this line
]),
```

Change 2 of 2 — auth.controller.js

Return tokens in the JSON body when the request comes from mobile. Web clients are unaffected — they never send x-client-type: mobile.

Apply the same pattern to both login and refresh:

```
// login()
const isMobile = req.get('x-client-type') === 'mobile';

return res.status(200).json({
  success: true,
  message: 'Login successful.',
  data: {
    user: result.user,
    ...(isMobile && {
      accessToken: result.accessToken,
      refreshToken: result.refreshToken,
    }),
  },
});
```

```
// refreshToken() – also read token from body as fallback
const token = req.cookies?.refreshToken ?? req.body?.refreshToken;

// then return the new pair in the body for mobile
const isMobile = req.get('x-client-type') === 'mobile';
return res.status(200).json({
  success: true,
  message: 'Access token refreshed successfully.',
  ...(isMobile && {
    data: { accessToken: result.accessToken,
      refreshToken: result.refreshToken }
  }),
});
```

3. Fix role enum mismatch

BUG

The problem

employee.model.js and employee.validator.js disagree on valid hierarchy level strings. A payload that passes Joi validation fails when Mongoose tries to save it.

employee.model.js (9 values)	employee.validator.js (8 values)
SUPER_ADMIN	SUPER_ADMIN
GOVERNANCE	GOVERNANCE
EXECUTIVE	EXECUTIVE
DEPARTMENT	DEPARTMENT_HEAD
MANAGER	MANAGER
TEAM_LEAD	TEAM_LEAD
TEAM	(missing)
EMPLOYEE	EMPLOYEE
INTERN	INTERN

Recommendation: The model is correct per FRS section 4 which lists nine levels. The validator should be updated to match: rename DEPARTMENT_HEAD to DEPARTMENT and add TEAM. Please confirm the spelling before it is hardcoded on the mobile side — it becomes a key in the permission engine, the navigation filter, and every role badge.

Not included in this request

The following are needed for later phases but do not block the current sprint. They will be requested separately when the backend is ready.

- Document CRUD endpoints — document module is currently 0 bytes
- Approval queue — GET /approvals/pending for the logged-in user
- Department and team listing — models exist but no routes are mounted
- Push notification hooks — needed for FRS section 10 escalation reminders
- Presigned S3 URLs for document upload and preview

EGKMS Mobile · Backend Change Request · Version 1.0 · Changes P0-1 and P0-2 together require fewer than 20 lines across 3 files and do not affect existing web behaviour.